

Procedure

- 1. Define the Scope:
 - Select a simple web application as the subject of the threat model. Define its purpose, architecture, and key components.
- 2. Create Diagrams:
 - Use a diagramming tool to create a Data Flow Diagram (DFD) of the application. Identify and label the different processes, data stores, data flows, and external entities.
- 3. Identify Threats Using STRIDE:
 - For each element in the DFD, apply the STRIDE methodology to identify potential threats. Use the following table to help categorize the threats:

Component	Threat Type	Description	Potential Threats
Login Page	Spoofing	Unauthorized users gaining access	Brute force attack
API	Tampering	Alteration of data in transit	Man-in-the-middle attack
Database	Information Disclosure	Unauthorized data access	SQL injection
Web Server	Denial of Service	Overloading the server	Distributed DoS attack
Admin Panel	Elevation of Privilege	Unauthorized admin access	Privilege escalation via vulnerabilities

- 1. Analyze and Propose Mitigations:
 - For each identified threat, propose a mitigating strategy. Consider implementing security best practices such as encryption, authentication

mechanisms, input validation, and intrusion detection systems.

1. Document the Findings:

- Compile all findings, diagrams, and proposed mitigations into a comprehensive report.

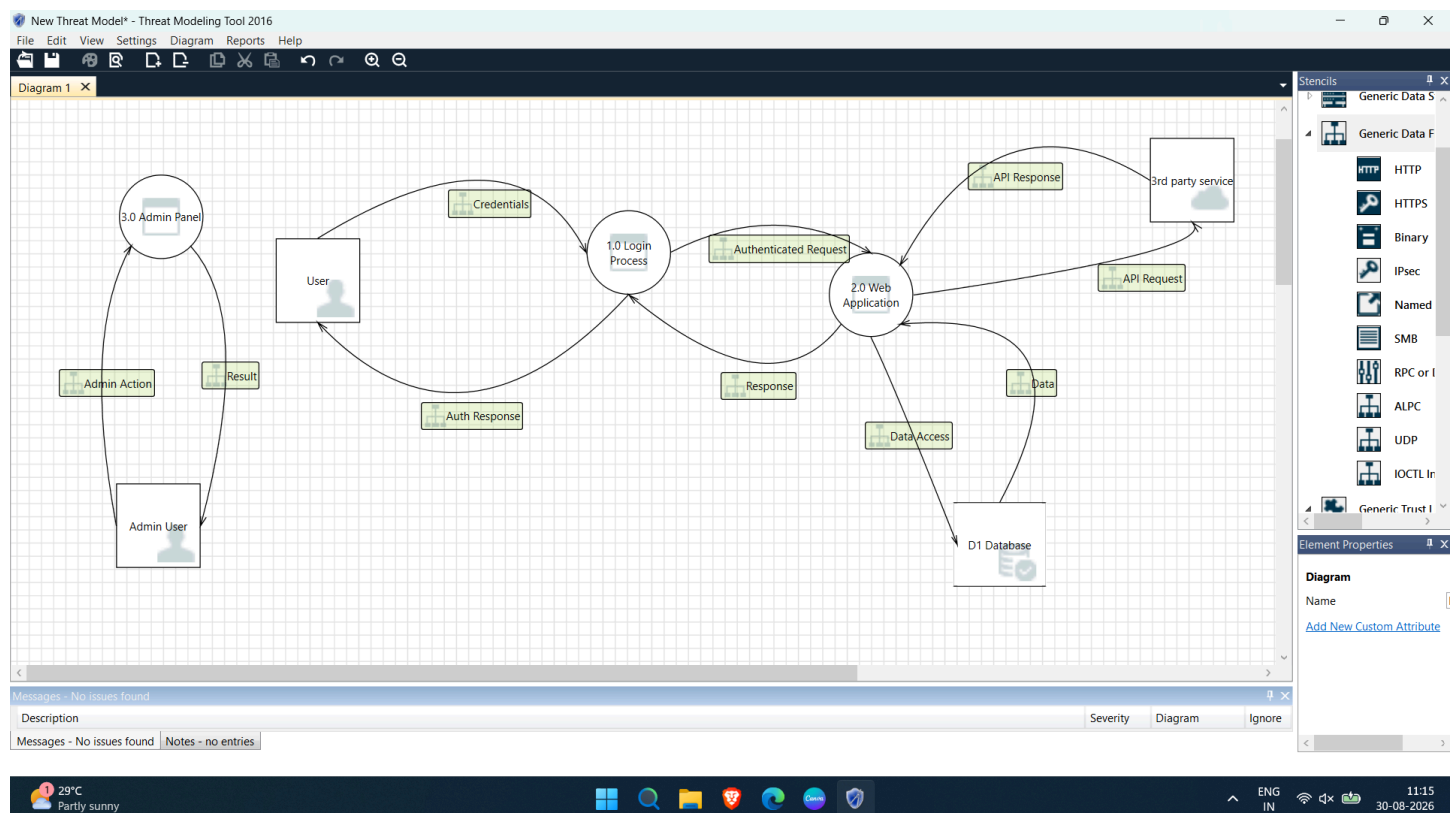
2. Review and Iterate:

- Have peers review the threat model and proposed mitigations. Revise and improve based on feedback.

By following these steps, we will gain hands-on experience in identifying potential security threats and developing strategies to mitigate them using the STRIDE methodology. This experiment not only enhances understanding of security principles but also equips individuals with practical skills in threat modeling.

Output Screenshots

(a) Creating Data Flow Diagram



(b) Generating and reviewing STRIDE threats

New Threat Model* - Threat Modeling Tool 2016

File Edit View Settings Diagram Reports Help

Diagram 1 X

Threat List

ID	Diagram	Changed By	Last Modified	State	Title	Category	Description	Interaction	Priority
0	Diagram 1	AAKASH\Aakas	30-08-2026 11:...	Not Started	Spoofing the...	Spoofing	User may be spoofed by an attacker and this may lead to unauthorized access to 1.0 Logi...	Credentials	Low
1	Diagram 1	AAKASH\Aakas	30-08-2026 11:...	Mitigated	Elevation Usin...	Elevation Of Privilege	1.0 Login Process may be able to impersonate the context of User in order to gain additio...	Credentials	Medium
2	Diagram 1	Generated		Not Started	Elevation Usin...	Elevation Of Privilege	2.0 Web Application may be able to impersonate the context of 1.0 Login Process in order...	Authenticated...	High
3	Diagram 1	Generated		Not Started	Elevation Usin...	Elevation Of Privilege	1.0 Login Process may be able to impersonate the context of 2.0 Web Application in order...	Response	High
4	Diagram 1	Generated		Not Started	Spoofing the 3...	Spoofing	3rd party service may be spoofed by an attacker and this may lead to unauthorized access...	API Response	High
5	Diagram 1	Generated		Not Started	Elevation Usin...	Elevation Of Privilege	2.0 Web Application may be able to impersonate the context of 3rd party service in order...	API Response	High
6	Diagram 1	Generated		Not Started	Spoofing of D...	Spoofing	D1 Database may be spoofed by an attacker and this may lead to data being written to th...	Data Access	High
7	Diagram 1	Generated		Not Started	Potential SQL I...	Tampering	SQL injection is an attack in which malicious code is inserted into strings that are later pas...	Data Access	High
8	Diagram 1	AAKASH\Aakas	30-08-2026 11:...	Not Started	Potential Exces...	Denial Of Service	Does 2.0 Web Application or D1 Database take explicit steps to control resource consump...	Data Access	Medium
9	Diagram 1	Generated		Not Started	Spoofing of S...	Spoofing	D1 Database may be spoofed by an attacker and this may lead to incorrect data delivere...	Data	High
10	Diagram 1	Generated		Not Started	Weak Access C...	Information Disclosure	Improper data protection of D1 Database can allow an attacker to read information not i...	Data	High
11	Diagram 1	Generated		Not Started	Spoofing the...	Spoofing	Admin User may be spoofed by an attacker and this may lead to unauthorized access to 3...	Admin Action	High
12	Diagram 1	Generated		Not Started	Elevation Usin...	Elevation Of Privilege	3.0 Admin Panel may be able to impersonate the context of Admin User in order to gain a...	Admin Action	High

13 Threats Displayed, 13 Total

Threat Properties

ID: 0 Diagram: Diagram 1 Status: Not Started Last Modified: AAKASH\Aakas 30-08-2026 11:18:03 AM

Title: Spoofing the User External Entity

Category: Spoofing

Description: User may be spoofed by an attacker and this may lead to unauthorized access to 1.0 Login Process. Consider using a standard authentication mechanism to identify the external entity.

Justification:

Interaction: Credentials

Threat Properties Notes - no entries

30°C Partly sunny

ENG IN 11:18 30-08-2026

(c) Adding Mitigations

0	Diagram 1	AAKASH\Aakas	30-08-2026 11:...	Not Started	Spoofing the Use...	Spoofing	User may be...	Credentials	Low
1	Diagram 1	AAKASH\Aakas	30-08-2026 11:...	Not Started	Elevation Using I...	Elevation Of Privilege	1.0 Login Pro...	Credentials	Medium
2	Diagram 1	AAKASH\Aakas	30-08-2026 11:...	Not Started	Elevation Using I...	Elevation Of Privilege	2.0 Web App...	Authenticated...	High
3	Diagram 1	Generated		Not Started	Elevation Using I...	Elevation Of Privilege	1.0 Login Pro...	Response	High
4	Diagram 1	Generated		Not Started	Spoofing the 3rd...	Spoofing	3rd party ser...	API Response	High
5	Diagram 1	Generated		Not Started	Elevation Using I...	Elevation Of Privilege	2.0 Web App...	API Response	High
6	Diagram 1	Generated		Not Started	Spoofing of Desti...	Spoofing	D1 Database...	Data Access	High
7	Diagram 1	AAKASH\Aakas	30-08-2026 11:...	Not Started	Potential SQL Inje...	Tampering	SQL injection...	Data Access	High
8	Diagram 1	AAKASH\Aakas	30-08-2026 11:...	Not Started	Potential Excessiv...	Denial Of Service	Does 2.0 We...	Data Access	Medium
9	Diagram 1	Generated		Not Started	Spoofing of Sour...	Spoofing	D1 Database...	Data	High
10	Diagram 1	AAKASH\Aakas	30-08-2026 11:...	Not Started	Weak Access Con...	Information Disclosure	Improper da...	Data	High
11	Diagram 1	Generated		Not Started	Spoofing the Ad...	Spoofing	Admin User...	Admin Action	High
12	Diagram 1	Generated		Not Started	Elevation Using I...	Elevation Of Privilege	3.0 Admin Pa...	Admin Action	High

13 Threats Displayed, 13 Total

Threat Properties

ID: 10 Diagram: Diagram 1 Status: Not Started Last Modified: AAKASH\Aakas 30-08-2026 11:20:45 AM

Title: Weak Access Control for a Resource

Category: Information Disclosure

Description: Improper data protection of D1 Database can allow an attacker to read information not intended for disclosure. Review authorization settings.

Justification: Use parameterized queries, least-privilege access, and encrypt sensitive data.

Interaction: Data

Priority: High

Threat Properties Notes - no entries